



HeeraMon

Security & Privacy Specification

Security Specification Document

Date of Preparation: September 30, 2026

Document ID	HM-DOC-11
Title	Security & Privacy Specification
Classification	Security Specification Document
Status	Draft
Version	1.0
Owner	Product / Engineering
Audience	All project contributors
Related Documents	Technical Architecture (HM-DOC-07), API Spec (HM-DOC-10)

Contents

1 Purpose	2
2 Core Principles	2
3 Authentication and Authorization	2
4 Data Protection	2
4.1 In Transit	3
4.2 At Rest	3
5 LLM Privacy Boundary	3
6 CV and Application Data	3
7 Secrets and External Credentials	4
8 Agent Security	4
9 External Job Sources	5
10 Agent Guardrails	5
10.1 Core Guardrails	5
10.2 Guardrail Design Principle	6
11 Application Automation Safety	6
12 Logging and Observability	6
13 Data Retention and Deletion	7
14 Common Security Protections	7
15 Privacy by Design	8
16 Boundaries	8
17 Success Criteria	8
18 Document Control	9

1 Purpose

This document defines the security and privacy requirements for HeeraMon.

HeeraMon handles personal information, career preferences, conversations, CVs, and potentially sensitive application data. Security and privacy must therefore be designed into the system from the beginning.

2 Core Principles

HeeraMon should follow these principles:

- Collect only information that is useful for the product.
- Give users control over their personal information.
- Keep user data isolated between accounts.
- Protect data in transit and at rest.
- Never expose secrets to the LLM unnecessarily.
- Treat external services as untrusted boundaries.
- Require explicit user approval for consequential actions.
- Log security-relevant events without unnecessarily logging private content.

3 Authentication and Authorization

Authentication should use a trusted authentication system.

The backend must enforce authorization for every protected resource.

A user must only be able to access:

- their own profile;
- their own preferences;
- their own conversations;
- their own jobs/matches;
- their own applications;
- their own notifications.

Authorization must be enforced server-side and must never depend on frontend checks alone.

4 Data Protection

Sensitive information should be protected both:

4.1 In Transit

- HTTPS/TLS for external communication.

4.2 At Rest

- encrypted database/storage infrastructure where provided by the platform;
- secure secret management;
- restricted infrastructure access.

Credentials, API keys, session tokens, and other secrets must never be committed to source control.

5 LLM Privacy Boundary

The LLM should receive only the information required for the current task.

The system should avoid unnecessarily sending:

- authentication credentials;
- API keys;
- private secrets;
- unrelated personal information;
- sensitive application data.

Provider-specific data retention and privacy policies should be reviewed before selecting production LLM providers.

The architecture should allow the LLM provider to be replaced without redesigning the rest of the application.

6 CV and Application Data

CVs and application materials should be treated as private user data.

Access should require authentication and authorization.

HeeraMon must never:

- invent qualifications;
- modify factual credentials without user visibility;
- submit an application without explicit approval;
- expose one user's CV or application information to another user.

Generated application content must remain reviewable before submission.

7 Secrets and External Credentials

Secrets should be stored using secure server-side mechanisms.

Examples include:

- LLM provider keys;
- database credentials;
- notification provider credentials;
- OAuth secrets;
- application integration credentials.

Secrets should never be:

- stored in frontend code;
- returned through normal API responses;
- included in logs;
- placed inside prompts unnecessarily.

If user-provided API keys or BYOK support is introduced later, those credentials require dedicated secure storage and handling.

8 Agent Security

The LLM must not have unrestricted access to the application.

Tool access should be:

- explicitly defined;
- permission-controlled;
- validated;
- auditable.

The agent must not be able to bypass:

- authorization;
- application state rules;
- approval requirements;
- rate limits;
- security controls.

User approval must be enforced by backend logic rather than relying solely on prompt instructions.

9 External Job Sources

External websites and job sources should be treated as untrusted input.

Job descriptions may contain malicious or manipulative content, including text attempting to influence the AI agent.

HeeraMon must treat retrieved job content as data, not as instructions.

External content must not be allowed to override:

- system instructions;
- user authorization;
- security policies;
- tool permissions.

10 Agent Guardrails

HeeraMon's agent must operate within explicit safety and authorization boundaries.

10.1 Core Guardrails

1. **Never invent facts** — The agent must not fabricate job information, user qualifications, company information, application answers, or tool results.
2. **Treat external content as untrusted data** — Job descriptions, websites, emails, and other retrieved content must never be treated as instructions to the agent.
3. **Never override user requirements silently** — The agent may identify conflicts or suggest exceptions, but must not silently change hard requirements.
4. **Never perform consequential actions without authorization** — Application submission, account changes, or other external actions require the appropriate explicit user approval.
5. **Respect tool boundaries** — The agent may only use tools exposed to it and may only perform operations permitted by those tools.
6. **Protect private information** — The agent should only access or transmit user data necessary for the current task.
7. **Validate before acting** — Important agent-generated structured data must be validated by deterministic backend logic before being persisted or used for external actions.
8. **Fail safely** — When uncertain, missing required information, or unable to verify an important result, the agent should stop, ask the user, or report the uncertainty rather than guessing.
9. **Maintain action traceability** — Important agent actions should be attributable to a user request, scheduled task, or authorized workflow.

10.2 Guardrail Design Principle

Guardrails should be implemented at multiple layers:

System Prompt → Agent / Tool Permissions → Backend Authorization & Validation → External Action

Prompt instructions provide behavioral guidance, but security-critical guardrails must be enforced outside the LLM.

The backend must remain the final authority for authorization, data access, state transitions, and consequential external actions.

11 Application Automation Safety

Application submission is a consequential action.

Before submission, HeeraMon must:

1. prepare the application;
2. show the user the information being submitted;
3. allow edits;
4. obtain explicit approval;
5. submit only after approval;
6. report the actual result.

The system must not claim an application was submitted unless the external system confirms the submission.

12 Logging and Observability

Logs should support debugging and security investigation without becoming a copy of users' private conversations.

Avoid logging sensitive values such as:

- passwords;
- API keys;
- authentication tokens;
- full CV contents;
- unnecessary personal information.

Security-relevant events should be auditable, including:

- authentication events;
- permission failures;

- important preference changes;
- application approval;
- application submission;
- administrative/security events.

13 Data Retention and Deletion

The system should define retention policies for:

- conversations;
- CVs;
- job data;
- application history;
- notifications;
- logs.

Users should eventually be able to request deletion of their account and associated personal data.

Deletion behavior should distinguish between:

- user-owned personal data;
- operational logs;
- third-party/source data;
- data required temporarily for security or legal purposes.

Specific legal retention requirements should be addressed before production expansion.

14 Common Security Protections

The system should include protection against common web vulnerabilities, including:

- SQL injection;
- XSS;
- CSRF where applicable;
- insecure direct object references;
- authentication/session attacks;
- rate-limit abuse;
- malicious file uploads;
- prompt injection;
- unauthorized tool execution.

Dependencies should be kept updated and security-sensitive functionality should use established libraries rather than custom cryptography.

15 Privacy by Design

Privacy should be considered when adding every major feature.

Before collecting a new category of data, HeeraMon should have a clear answer to:

- Why is this data needed?
- Who can access it?
- How long is it retained?
- Does it need to be sent to an external provider?
- Can the feature work with less data?

16 Boundaries

The initial release does not require:

- enterprise SSO;
- complex compliance infrastructure;
- custom encryption systems;
- dedicated security operations teams;
- advanced threat intelligence;
- enterprise-grade audit platforms.

However, security must not be treated as a feature to add later.

17 Success Criteria

The security and privacy implementation is successful when:

1. Users can securely authenticate.
2. User data is isolated between accounts.
3. Sensitive information is protected.
4. Secrets remain outside frontend code and normal logs.
5. LLM access is appropriately constrained.
6. External job content cannot override agent security boundaries.
7. Applications require explicit user approval.
8. Important security actions are auditable.
9. The system has a clear path toward user data deletion and stronger privacy controls.

Core principle: HeeraMon should earn trust by making user control and data protection part of the architecture, not merely promises in the interface.

18 Document Control

Version	Date	Author / Role	Changes
1.0	September 30, 2026	Product / Engineering	Initial release

Approval: This document defines the security and privacy requirements for HeeraMon. All subsequent design and implementation work must remain consistent with the principles stated herein.

HeeraMon flies to help people find job that fits not only their career, but the life they want to live.



Saadman Sakib
Product Engineer